Chapter 9:
Key Generation: Efficiently generate key pairs.
Encryption: Efficiently encrypt with public key.
Decryption: Efficiently decrypt with private key.
Private Key Security: Cannot derive private key from public key.
Message Security: Cannot recover plaintext from public key & ciphertext.
Key Order: Keys must work in either order.
$n=pq$ $\Phi(n)=(p-1)(q-1)$ $e \perp \Phi(n)$ $ed\%\Phi(n)=1$ $\mathbf{C=M^e \%n}$
$E_{RecieverPublic}(M+E_{SenderPrivate}(H_{ash}(M)))$
RSA attacks: Brute-force, probable-message, and private-key recovery.
Timing attack defenses: Constant time (eliminate timing differences), random delays (add noise), blinding (randomize ciphertext)`

Chapter 10 (Diffie-Hellman):
Diffie-Hellman: p = public prime modulus; g = public starting base. Exchange $g^a \%$ p and $g^b \%$ p, then calculate the same shared secret $g^{ab} \%$ p

Chapter 11 (Hash):
Hash Function: Takes an input of any length and produces a fixed-length hash. Used primarily for data integrity. $h = H(M)$
6 Hash Function Properties: Variable Input Size, Fixed Output Size, Efficiency,
4. Preimage Resistance: Given a hash, infeasible to find a message that produces it.
5. Second Preimage Resistance: Given a message, infeasible to find another message with the same hash.
6. Collision Resistance: Infeasible to find any two different messages with the same hash.
Digital Signature: Hash message → Encrypt w/ sender private key → Decrypt w/ sender public key → Compare hashes
Other Uses: one-way password file, intrusion and virus detection, pseudorandom function
Attacks: Brute force, cryptanalysis,
Birthday Attack: Generates and compares message hashes to find different messages with the same hash. Requires ~$2^{n/2}$ attempts for an n-bit hash
Yuval attack: Creates legitimate and fraudulent message variations with matching hashes to misuse a digital signature.

Chapter 12 (Message Authentication Code / MAC):
MAC = $H_{ash}(M_{\mathbf{essage}}+S_{\mathbf{ecretKey}})$ **Special keyed hash H(k, M)*
Message Authentication Attacks:
1. Disclosure *(Confidentiality)*: Unauthorized person reads the message.
2. Traffic Analysis *(Confidentiality)*: Attacker observes communication patterns to gather information.
`3. Masquerade *(Message Authentication)*: Attacker impersonates a legitimate sender.
4. Content Modification *(Message Authentication)*: Attacker inserts, deletes, or changes message contents.
5. Sequence Modification *(Message Authentication)*: Attacker inserts, deletes, or reorders messages in a sequence.
6. Timing Modification *(Message Authentication)*: Attacker delays or replays messages.
7. Source Repudiation *(Non-repudiation)*: Sender denies having transmitted the message.
8. Destination Repudiation *(Non-repudiation)*: Receiver denies having received the message.
MAC-then-Encrypt (MtE): E(M ∥ MAC). Fragile because receiver must decrypt before verifying; can expose padding-oracle vulnerabilities.
Encrypt-then-MAC (EtM): E(M) ∥ MAC(E(M)). Recommended. Verify MAC before decrypting.
Encrypt-and-MAC (E&M): E(M) ∥ MAC(M). Identical plaintext messages produce identical MAC tags.
Requirements for MAC: Forgery Resistance, Uniform Distribution, No Weak Message Bits
Key Brute-Force (Offline): Attacker tries possible secret keys until finding one that produces the known MAC tag.
Tag Guessing (Online): Attacker guesses a valid MAC tag and submits it for verification. Defenses: rate-limiting and locking out repeated failures.
Cryptanalysis: Exploiting weaknesses in a cryptographic algorithm to forge valid MACs or bypass security without knowing the secret key.

Chapter 13 (Digital Signature):
Properties: Author & Timestamp, Content Authentication, Third-Party Verification
Requirements:
1. Message Dependency: Signature must depend on the message being signed.
2. Sender Uniqueness: Uses information unique to the sender (private key) to prevent forgery and denial.
3. Easy to Produce: Generating a signature must be efficient.
4. Easy to Verify: Verifying a signature must be efficient.
5. Forgery Resistance: Computationally infeasible to create a fake signature or forge one for another message.
6. Practical Storage: Signatures must be easy to store for future verification.
Attacks:
1. Key-only: Only the public key is known.
2. Known-message: Existing messages and signatures are available.
3. Generic chosen-message: Attacker chooses messages before requesting signatures.
4. Directed chosen-message: Attacker chooses messages after learning the public key but before seeing signatures.
5. Adaptive chosen-message: Attacker chooses new messages based on previously obtained signatures.
Forgeries:
1. Total Break: Attacker discovers the sender's private key.
2. Universal Forgery: Attacker finds an equivalent signing method that can create valid signatures for arbitrary messages.
3. Selective Forgery: Attacker creates a valid signature for a particular message of their choosing. Existential Forgery:
4. Attacker creates a valid signature for at least one message, but has no control over the message.

Chapter 15:
Symmetric Key Distribution: Securely deliver a shared secret key to both parties without exposing it to others
1. Physical delivery by sender.
2. Physical delivery by a trusted third party.
3. Encrypt a new key using the old shared key.
4. Trusted third party distributes the key over encrypted connections
Key Management: Secure generation, storage, distribution, use, and replacement of cryptographic keys.
Frequent key changes limit damage if a key is compromised.
Certificate Authority: Trusted third party that verifies identities and issues digital certificates connecting identities to public keys.
CA digitally signs certificates to authenticate them and detect unauthorized modifications.
Digital Certificate (X.509): Contains the owner's identity, public key, CA's digital signature, & validity period
Public Key Distribution:
Public Announcement: Users openly publish their public keys, but attackers can publish fake keys pretending to be someone else.
Public Directory: Centralized directory that stores users' identities and public keys for others to access.
Public Key Authority: Trusted online authority that provides authenticated public keys upon request.
Public Key Certificate: CA-signed document that binds an identity to a public key.

CISSP Material:
Asymmetric encryption distributes session keys; symmetric encryption efficiently encrypts bulk data.
Private key compromise allows decryption and impersonation through forged signatures
PKI (Public Key Infrastructure): System of CAs, Digital Certificates, and procedures to verify public-key ownership
establish trust in public-key communications
Scalability: Asymmetric encryption requires $2n$ keys for n users, compared with $\frac{n(n-1)}{2}$ shared keys for symmetric encryption.
Key Distribution: Asymmetric encryption allows public keys to be shared openly, eliminating the need to secretly exchange a shared key beforehand.
Key Revocation: If a private key is compromised, it must be revoked and replaced. Other users' keys do not automatically need replacement.
Kerckhoffs's Principle: A cryptosystem should remain secure even if everything about the system is public except the secret key.
Advantages: Easier key distribution, supports digital signatures, and scales better.
Disadvantages: Slower than symmetric encryption and computationally more expensive.

CEH Material (Asymmetric Encryption):
RSA Key Sizes: RSA key sizes of 1,024, 2,048, and 4,096 bits. Larger RSA keys provide greater security.
Key Size Comparison: RSA and AES key lengths cannot be directly compared because they use different cryptographic algorithms.
Hybrid Cryptosystem: Combines asymmetric and symmetric encryption. Asymmetric protects the session key, symmetric protects data
Nonrepudiation: Message originated from owner of a private key. Requires protecting the private key from unauthorized use.
Certificate Fingerprint: Fixed-length hex value used to identify a public key.
Root CA: Highest-level trusted authority. Establishes foundation of trust by signing & authorizing CAs, which issue certificates to users and servers.
Chain of Trust: Root CA → Intermediate CA → Website/User Certificate.
Certificate Validation: The certificate must be issued by a trusted authority, and its hostname must match the server being accessed.
Certificate Revocation List (CRL): List maintained to identify certificates that have been revoked and should no longer be trusted.
OCSP (Online Certificate Status Protocol): Allows a system to check a certificate's validity status with a CA.
Self-Signed Certificate: Certificate signed by its own creator rather than a trusted CA. It does not automatically establish trust.

CEH Material (Hash):
MD5: Produces a 128-bit hash (32 hex). Considered deprecated due to collision vulnerabilities.
SHA-1: Produces a 160-bit hash (40 hex). Superseded by stronger hashing algorithms.
SHA-2: Produces hashes of 224, 256, 384, or 512 bits. Offers stronger collision protection than MD5 and SHA-1.
SHA-3: Supports 224, 256, 384, and 512-bit hashes. Uses a different internal design from SHA-1 and SHA-2.
Avalanche Effect: Changing even one bit of the input produces a drastically different hash output.
File Integrity Verification: Calculate a downloaded file's hash and compare it against a known-good hash to detect corruption or modification.
File Integrity Monitoring: Systems such as Tripwire store known-good hashes and periodically compare them against current files to detect unauthorized changes.

Confidentiality: Prevents unauthorized disclosure of information.
Integrity: Protects against unauthorized modification of information.
Availability: Ensures systems and resources remain accessible to authorized users.